

Exercice 1 : Adversary-in-the-Middle (AiTM), Tycoon2FA et Mamba2FA

Nom et Prénom : _____

Tycoon2FA et Mamba2FA reposent sur le même principe. Le kit place un serveur relais entre la victime et le vrai service de connexion, le plus souvent Microsoft 365. La victime tape son mot de passe et valide sa MFA sur une fausse page, mais tout est transmis en direct au vrai service : l'authentification est donc réelle. À la fin, le relais récupère le cookie de session que le service délivre après la MFA. L'attaquant n'a plus qu'à le réutiliser pour entrer dans le compte, sans mot de passe ni MFA.

Tycoon2FA

Tycoon2FA est vendu comme un service (Phishing-as-a-Service) depuis au moins août 2023. Sekoia a été le premier à l'analyser en détail, et Microsoft attribue son développement à un acteur qu'il appelle Storm-1747. L'abonnement se prenait sur Telegram, puis sur Signal : 120 USD pour 10 jours, 350 USD pour un mois. Le client dispose d'un panneau d'administration où il choisit ses modèles de page et ses redirections, et suit ses victimes.

I. Mode opératoire

Le kit ne casse pas la MFA, il la fait valider par la victime. Tout ce qui se saisit ou s'approuve à la main (SMS, code OTP, notification push, appel) peut donc être relayé. La faiblesse de fond est ailleurs : le cookie de session obtenu après la MFA reste utilisable depuis une autre machine, et Sekoia note qu'un simple changement de mot de passe ne suffit pas forcément à l'invalider. Le kit joue aussi sur la confiance de l'utilisateur, avec le logo de son entreprise et son adresse e-mail déjà remplie.

L'attaque se déroule en cinq temps :

1. La victime reçoit un e-mail avec un lien, un QR code ou une pièce jointe (PDF, DOCX, SVG, HTML) : faux DocuSign, message vocal, facture, document OneDrive, etc.
2. Elle passe par plusieurs redirections et un CAPTCHA (Cloudflare Turnstile au début, puis des CAPTCHA maison). Pendant ce temps, le kit écarte les IP de datacenters et de Tor, les bots et les outils comme Burp ou PhantomJS ; un analyste repéré tombe sur un leurre ou une page 404. Les domaines changent très vite, souvent au bout de 24 à 72 h.
3. Elle arrive sur une copie de la page de connexion Microsoft 365 ou Gmail. Identifiant, mot de passe puis code MFA partent en direct vers le vrai service.
4. Le relais intercepte le cookie de session et l'envoie à l'attaquant (Socket.IO/WebSocket), dans son panneau ou sur un bot Telegram.
5. La victime est renvoyée vers une page légitime ou une erreur Microsoft et ne se doute de rien.

En 2026, eSentire a observé une variante qui ne demande même plus de mot de passe. Elle détourne le flux OAuth « device code » : la victime tape un code sur le vrai site `microsoft.com/devicelogin`, et c'est le client de l'attaquant qui reçoit les jetons.

II. Impact

Tycoon2FA a été l'un des kits les plus utilisés de ces dernières années. D'après Microsoft, il représentait vers la mi-2025 environ 62 % des tentatives de phishing bloquées, soit plus de 30 millions d'e-mails en un mois, et ses campagnes touchaient plus de 500 000 organisations par mois. Microsoft compte environ 96 000 victimes depuis 2023, surtout dans l'éducation, la santé, la finance et le secteur public.

Une fois dans le compte, les attaquants volent des données, créent des règles de messagerie et ajoutent leur propre méthode MFA pour garder l'accès. Le compte sert ensuite à envoyer d'autres phishings ou à monter des fraudes au virement (BEC), et il ouvre parfois la voie à un ransomware.

Le 4 mars 2026, Microsoft, Europol et six pays européens ont saisi 330 domaines liés au kit. Il n'a pas disparu pour autant : Okta relevait encore 631 tentatives en avril 2026.

III. Prévention et défense

La parade la plus solide est une MFA résistante au phishing : clé FIDO2 ou passkey, Windows Hello for Business, certificat. La signature produite est liée au nom de domaine légitime. Sur un domaine de phishing elle ne fonctionne pas, et elle ne peut pas être rejouée. Sous Microsoft Entra, on peut compléter avec l'accès conditionnel :

- exiger un appareil conforme et activer Token Protection, qui lie le jeton à l'appareil, pour qu'un cookie volé ne serve à rien ailleurs ;
- redemander une authentification forte quand une connexion est jugée risquée, et activer CAE pour que la révocation soit quasi immédiate ;
- bloquer le flux device code pour les utilisateurs qui n'en ont pas besoin.

Côté détection, Defender remonte des alertes dédiées (« Stolen session cookie was used », « User compromised in AiTM phishing attack ») et Entra des signaux comme *Anomalous Token*. Microsoft publie aussi des requêtes KQL pour chercher ces connexions. Le filtrage des e-mails (Safe Links, Safe Attachments, ZAP) et les simulations de phishing réduisent le nombre de clics.

Après une compromission, changer le mot de passe ne suffit pas : il faut aussi révoquer sessions et jetons, retirer la MFA ajoutée par l'attaquant et vérifier règles de transfert et consentements OAuth.

Mamba2FA

Mamba2FA a été décrit par Sekoia en octobre 2024 (ANY.RUN avait déjà analysé une campagne en juin), mais il circulait depuis au moins novembre 2023. Vendu d'abord sur ICQ puis sur Telegram, il coûte 250 USD par mois. Le client reçoit un bot Telegram qui lui fabrique à la demande ses liens de phishing et ses pièces jointes HTML.

I. Mode opératoire

La faiblesse exploitée est la même que pour Tycoon2FA : les codes OTP et les notifications push peuvent être relayés, et le cookie de session reste réutilisable. Sekoia ne relève aucune faille dans Microsoft 365 ou Entra ID eux-mêmes. Le kit vise large : comptes Entra ID, AD FS, SSO tiers et comptes Microsoft personnels. Il charge même le logo et le fond d'écran de l'organisation ciblée.

Le déroulement observé par Sekoia :

1. La victime reçoit une pièce jointe HTML, ou un lien vers un fichier hébergé sur Cloudflare R2 ou IPFS. Le fichier est rempli de texte anodin caché en CSS. Seul compte un petit script qui redirige vers une URL encodée en Base64.
2. L'URL a la forme `/{m,n,o}/?{Base64}`. Sans paramètre valide, la page reste vide. Avec, elle affiche un modèle OneDrive, SharePoint, messagerie vocale ou Microsoft générique, avec l'e-mail de la victime prérempli.
3. Une sandbox ou un navigateur automatisé est renvoyé vers `google.com/404`. L'infrastructure a deux couches : des domaines de liens anti-bot, changés chaque semaine, et des serveurs relais qui durent plus longtemps.
4. La page échange avec le relais par Socket.IO (WebSocket, ou long-polling à défaut). Chaque saisie part au relais (`password_command`, `otp_command`), qui se connecte à Microsoft à la place de la victime.
5. Quand les cookies arrivent (`s2c_cookies`), la victime est redirigée ailleurs, et identifiants et cookies tombent aussitôt sur le bot Telegram de l'attaquant.

Depuis octobre 2024, le relais passe par des proxies commerciaux (IPRoyal). Dans les journaux Entra, on ne voit donc plus l'IP du serveur relais, seulement une IP de datacenter.

II. Impact

Mamba2FA est moins visible que Tycoon2FA, et son ampleur est donc plus difficile à mesurer. Sekoia l'a retrouvé chez plusieurs de ses clients avant même de publier son rapport. De janvier à avril 2025, il le classait 9^e des kits AiTM, en précisant que ce rang le sous-estime probablement. Fin 2025, Barracuda a compté près de 10 millions d'attaques.

Les conséquences sont celles de toute compromission AiTM d'un compte cloud : fraude au virement, vol d'e-mails et de fichiers, phishing envoyé depuis le compte volé, fausses factures. L'attaquant garde souvent la main en ajoutant sa propre méthode MFA ou une règle de transfert. Contrairement à Tycoon2FA, aucun démantèlement ni aucune arrestation n'a été rendu public.

III. Prévention et défense

Les défenses sont en grande partie les mêmes. La MFA résistante au phishing reste la réponse directe, puisque le relais peut transmettre un code OTP mais pas une signature liée au vrai domaine. L'accès conditionnel (appareil conforme, Token Protection, politiques de risque, CAE, emplacements nommés par IP) limite ce que l'attaquant peut faire d'un cookie volé.

Certains indices sont propres à Mamba2FA : des connexions depuis les IP et domaines relais publiés par Sekoia (dont les proxies IPRoyal), des URL au format `/{m,n,o}/?{Base64}`, des redirections vers `google.com/404`, ou des incohérences entre User-Agent et Application ID dans les journaux Entra ID. Comme le kit passe surtout par des pièces jointes HTML, il vaut la peine d'analyser les pièces jointes (Safe Attachments, ZAP) et d'apprendre aux utilisateurs à se méfier des fichiers HTML qu'ils n'attendaient pas.

En cas de compromission, on applique la même réponse que pour Tycoon2FA : nouveau mot de passe, révocation des sessions et jetons, réenregistrement de la MFA, suppression des règles de transfert, contrôle des consentements OAuth.

Sources. Sekoia, *Tycoon 2FA : an in-depth analysis* (25/03/2024) ; Sekoia, *Mamba 2FA : a new contender in the AiTM phishing ecosystem* (07/10/2024) ; Sekoia, *Global analysis of AiTM phishing threats* (11/06/2025) ; Microsoft Security Blog, *Inside Tycoon2FA* (04/03/2026) ; Microsoft On the Issues, *How a global coalition disrupted Tycoon* (04/03/2026) ; Proofpoint, *Disruption targets Tycoon 2FA* (04/03/2026) ; Okta, *Tycoon 2FA phishing actors scatter* (03/05/2026) ; eSentire, *Tycoon 2FA operators adopt OAuth device code phishing* (12/05/2026) ; Barracuda, *Phishing kits evolved in 2025* (01/2026) ; Microsoft Learn : *Authentication strengths, Passkeys (FIDO2), Token protection, Continuous access evaluation, Protecting tokens in Microsoft Entra ID* ; FIDO Alliance, *Passkeys : The Journey to Prevent Phishing* (03/2025).